

Encuesta Integral CTEM (Gestión Continua de la Exposición a Amenazas)

Versión 1.0 – Borrador para validación con responsables de ciberseguridad, riesgo, continuidad de negocio y dirección.

0. Instrucciones generales para la organización encuestada

Esta encuesta tiene como objetivo conocer el grado de adopción real (no declarativa) de prácticas de Gestión Continua de la Exposición a Amenazas (CTEM) en su organización, así como la forma en que se miden los indicadores asociados (técnicos, de negocio, regulatorios y de resiliencia).

No buscamos un examen de perfección, sino una radiografía honesta de:

- Qué están midiendo.
- Con qué frecuencia lo miden.
- Qué decisiones se toman a partir de esos números.

Cuando dude entre dos respuestas, elija la que mejor refleje la práctica habitual, no el procedimiento teórico.

1. Datos generales de la organización

1.1. Tipo de entidad (marque todas las que apliquen)

- ☐ Administración pública (AGE, CCAA, entidad local)
- ☐ Entidad financiera (banca, seguros, servicios de pago)
- ☐ Operador de servicios esenciales (energía, agua, transporte, salud, etc.)
- ☐ Empresa privada no regulada bajo NIS2/DORA
- ☐ Proveedor de servicios TIC / Cloud / Telecom
- ☐ Otra (especifique): ____

1.2. Tamaño aproximado de la organización (empleados)

- ☐ Menos de 250
- ☐ Entre 250 y 1.000
- ☐ Entre 1.001 y 5.000
- ☐ Más de 5.000

1.3. Alcance geográfico de sus operaciones

- ☐ Principalmente España
- ☐ España y algunos países de la UE
- ☐ Operación global

1.4. Rol principal de la persona que responde

- ☐ CISO / Responsable de Seguridad de la Información
- ☐ CIO / CTO
- ☐ Responsable de Riesgos / Compliance
- ☐ Responsable de Continuidad de Negocio / Resiliencia
- ☐ Dirección general / miembro del Consejo
- ☐ Otro (especifique): ____

2. Enfoque general de CTEM y gobernanza

2.1. ¿Dispone su organización de un programa formal de Gestión Continua de Exposición a Amenazas (CTEM) o equivalente, aunque reciba otro nombre?

- ☐ Sí, existe un programa formal CTEM reconocido por dirección.
- ☐ Sí, existen prácticas equivalentes, pero no se denominan CTEM.
- ☐ No, pero estamos en fase de diseño o piloto.
- ☐ No, no existe nada comparable (por ahora).

2.2. ¿Quién es el responsable último (sponsor) del programa CTEM o equivalente?

- ☐ CISO / Responsable de Seguridad de la Información.
- ☐ CIO / Dirección de Tecnología.
- ☐ Dirección de Riesgos / Cumplimiento.
- ☐ Dirección General / Consejo.
- ☐ No existe un responsable claramente designado.
- ☐ No aplica (no hay programa CTEM).

2.3. ¿Con qué frecuencia se revisa la exposición global a amenazas en foros de dirección o comités de riesgo?

- ☐ Al menos mensualmente.
- ☐ Trimestralmente.
- ☐ Semestralmente.
- ☐ Anualmente.
- ☐ De forma ad hoc, tras incidentes o auditorías.
- ☐ Nunca se presenta de forma estructurada.

2.4. ¿En qué medida la exposición a amenazas influye en las decisiones de inversión en ciberseguridad?

- ☐ Es el criterio principal (las inversiones se priorizan según exposición y riesgo).
- ☐ Es uno de varios criterios relevantes (junto con cumplimiento, tecnología, etc.).
- ☐ Se tiene en cuenta de forma marginal o informal.
- ☐ Prácticamente no se utiliza para priorizar inversiones.
- ☐ No sabe / No responde.

2.5. ¿Dispone de un modelo formal que conecte exposición a amenazas con riesgo de negocio (pérdidas, interrupciones, daño reputacional)?

- ☐ Sí, cuantitativo (pérdidas esperadas, escenarios, etc.).
- ☐ Sí, cualitativo (niveles de riesgo, matrices, etc.).
- ☐ Parcial, en algunos ámbitos o proyectos.
- ☐ No, no existe esa conexión formal.
- ☐ No sabe / No responde.

3. Fase de alcance (scoping)

3.1. ¿Cómo define su organización el alcance del programa CTEM?

- ☐ Se basa en un inventario claro de activos críticos de negocio.
- ☐ Se define por proyectos o iniciativas específicas.
- ☐ Se limita a determinados entornos (por ejemplo, sólo externo o sólo cloud).
- ☐ Se redefine principalmente tras auditorías o incidentes.
- ☐ No existe una definición clara de alcance.

3.2. ¿Qué criterios se utilizan para considerar un activo como “crítico” en CTEM?

- ☐ Impacto directo en la continuidad de servicios esenciales.
- ☐ Impacto financiero directo (ingresos, sanciones, etc.).
- ☐ Impacto regulatorio (NIS2, DORA, sectorial, etc.).
- ☐ Impacto reputacional significativo.
- ☐ Criterio técnico (por ejemplo, privilegios, conectividad).
- ☐ No se utilizan criterios explícitos; se decide caso a caso.

3.3. ¿Con qué frecuencia se revisa la lista de activos críticos relevantes para CTEM?

- ☐ Mensualmente.
- ☐ Trimestralmente.
- ☐ Anualmente.
- ☐ Sólo tras cambios importantes (proyectos, adquisiciones, etc.).
- ☐ No se revisa de forma sistemática.

3.4. En una escala del 1 al 5, ¿en qué medida considera que la definición de alcance de CTEM refleja la realidad de su negocio?

- ☐ 1 – Muy poco (es más un ejercicio formal que real).
- ☐ 2 – Limitado (cubre sólo una parte de lo relevante).
- ☐ 3 – Aceptable (cubre lo esencial, pero con lagunas).
- ☐ 4 – Bueno (representa bien las prioridades actuales).
- ☐ 5 – Excelente (está claramente alineado con la estrategia y riesgos).

4. Fase de descubrimiento (discovery) y superficie de ataque

4.1. ¿Dispone de mecanismos automatizados para el descubrimiento continuo de activos expuestos externamente (dominios, IP, servicios)?

- ☐ Sí, con herramientas dedicadas de descubrimiento y gestión de superficie de ataque.
- ☐ Parcialmente, combinando varias herramientas (por ejemplo, escáneres, ASM, etc.).
- ☐ Sólo realizamos descubrimientos puntuales (auditorías, pentests, etc.).
- ☐ No, no realizamos descubrimiento sistemático.

4.2. ¿Incluye el descubrimiento de activos “sombra” (shadow IT, servicios no inventariados, entornos no autorizados)?

- ☐ Sí, de forma explícita y recurrente.
- ☐ A veces se detectan, pero no es un objetivo formal.
- ☐ No, no se contempla activamente.
- ☐ No sabe / No responde.

4.3. ¿Con qué frecuencia actualiza su organización el inventario de activos tecnológicos relevantes para CTEM?

- ☐ En tiempo casi real (alimentación automática desde CMDB, cloud, redes, etc.).
- ☐ Semanalmente.
- ☐ Mensualmente.
- ☐ Trimestralmente o menos.
- ☐ No existe un inventario integrado.

4.4. ¿Qué métricas utiliza para describir su superficie de ataque externa?

Marque todas las que apliquen:

- ☐ Número de dominios y subdominios activos.
- ☐ Número de IP públicas asignadas y activas.
- ☐ Número de servicios expuestos por tipo (web, VPN, correo, etc.).
- ☐ Porcentaje de activos descubiertos que no estaban inventariados.
- ☐ Otro (especifique brevemente): ____
- ☐ No se utilizan métricas específicas de superficie de ataque.

4.5. ¿Se realiza también descubrimiento de exposición interna (segmentación, rutas laterales, privilegios excesivos, etc.)?

- ☐ Sí, mediante herramientas específicas (BAS, simulación, análisis de permisos, etc.).
- ☐ Parcialmente, en ámbitos acotados (por ejemplo, AD, cloud).
- ☐ Sólo de forma puntual (auditorías, ejercicios red team, etc.).
- ☐ No se explora la exposición interna de forma sistemática.

5. Fase de priorización (prioritization) e indicadores de exposición

5.1. ¿Cómo se priorizan las exposiciones identificadas en su organización?

- ☐ En función del impacto en activos críticos de negocio.
- ☐ Según severidad técnica (CVSS o similar).
- ☐ Según existencia de amenazas activas / exploits conocidos.
- ☐ Según disponibilidad de recursos para remediar (criterio pragmático).
- ☐ No existe un criterio claro; se decide caso a caso.

5.2. ¿Utiliza su organización puntuaciones estandarizadas para priorizar exposiciones?

- ☐ Sí, CVSS u otros sistemas de severidad técnica.
- ☐ Sí, EPSS u otros modelos de probabilidad de explotación.
- ☐ Sí, puntuaciones internas de riesgo de negocio.
- ☐ Sí, una combinación de varios sistemas.
- ☐ No, no utilizamos puntuaciones estandarizadas.

5.3. ¿Existen indicadores que combinen exposición técnica con impacto de negocio (por ejemplo, índices de “exposición crítica” por servicio)?

- ☐ Sí, se han definido y se utilizan regularmente.
- ☐ Sí, pero sólo en algunos ámbitos o proyectos.
- ☐ No, pero estamos trabajando en ello.
- ☐ No, no existen indicadores de este tipo.

5.4. ¿Qué indicadores de exposición utiliza habitualmente para informar a dirección o al consejo?

Marque las opciones que apliquen y valore su uso:

- ☐ Número de vulnerabilidades críticas/altas abiertas en activos críticos (uso: alto / medio / bajo).
- ☐ Número de rutas de ataque explotables hacia activos críticos (uso: alto / medio / bajo).
- ☐ Índices agregados de riesgo o exposición (scores CTEM, ASM, etc.) (uso: alto / medio / bajo).
- ☐ Comparativas de exposición por unidad de negocio o proveedor (uso: alto / medio / bajo).
- ☐ Otro (especifique): ____.

5.5. ¿Incluye la priorización aspectos relativos a identidad, accesos privilegiados y terceros/proveedores?

- ☐ Sí, plenamente integrados en la priorización.
- ☐ Parcialmente (por ejemplo, sólo terceros críticos).
- ☐ De forma puntual y react- ☐ Parcialm están fuera del alcance actual.

6. Fase de validación (validation) y simulación de ataques

6.1. ¿Realiza su organización simulaciones de ataque (BAS, red teaming, purple teaming, ejercicios adversariales) ligadas a las exposiciones identificadas por CTEM?

- ☐ Sí, de forma continua o muy regular (al menos mensual).
- ☐ Sí, de forma periódica (trimestral / anual).
- ☐ Sólo de forma puntual (proyectos, auditorías, etc.).
- ☐ No, no se realizan simulaciones ligadas a CTEM.

6.2. ¿Qué porcentaje aproximado de las exposiciones “críticas” identificadas se validan como explotables mediante pruebas prácticas o simuladas?

- ☐ Más del 75 %.
- ☐ Entre el 50 % y el 75 %.
- ☐ Entre el 25 % y el 50 %.
- ☐ Menos del 25 %.
- ☐ No se mide / No se sabe.

6.3. ¿Se miden indicadores de eficacia de controles (EDR, WAF, firewalls, IAM, etc.) frente a los escenarios de ataque derivados de CTEM?

- ☐ Sí, se miden sistemáticamente (tasa de detección, bloqueo, etc.).
- ☐ Sí, pero sólo en ejercicios específicos.
- ☐ Se revisa de forma cualitativa, sin métricas formales.
- ☐ No, no se miden de forma explícita.

6.4. ¿Existe un proceso formal para actualizar reglas, políticas o arquitectura a partir de los resultados de validación?

- ☐ Sí, con ciclo de mejora continua documentado.
- ☐ Parcialm de forma informal.
- ☐ Sólo tras incidentes graves.
- ☐ No, no existe tal proceso.

6.5. ¿Con qué frecuencia se revisan y actualizan los escenarios de ataque utiliz- ☐ Parcialmgrama CTEM?

- ☐ Al menos mensual.
- ☐ Trimestral.
- ☐ Parcialm ☐ Sólo cuando hay grandes cambios tecnológicos.
- ☐ No se rev- ☐ Parcialmsistemática.

7. Fase de movilización (mobilization),- ☐ Parcialm SLAs

7.1. ¿Dispone su organización de SLAs formales de re- ☐ Parcialm exposiciones críticas y altas?

- ☐ Sí, con plazos definidos (por ejemplo, - ☐ Parcialmeguimiento.
- ☐ Sí, pero los plazos no se controlan de manera est- ☐ Parcialmólo existen SLAs para ciertos tipos de vulnerabilidades o entornos.
- ☐ No, no ha- ☐ Parcialms.

7.2. ¿Qué porcentaje aproximado de exposiciones críticas se remedia dentro del SLA establecido?

- ☐ Parcialm90 %.
- ☐ Entre el 70 % y el 90 %.
- ☐ Entre el 50 % y el 7- ☐ Parcialmos del 50 %.
- ☐ No se mide / No aplica.

7.3. ¿Cómo se mide el tiempo medio de remediación (MTTR) en el contexto CTEM?

- ☐ Parcialmde forma sistemática y se reporta a dirección.
- ☐ Se mide, pero sólo internamente en el eq- ☐ Parcialm- ☐ Se mide de forma ocasional o manual.
- ☐ No se mide el MTTR.

7.4. ¿Dispone de métricas de “velocidad de remediación” (reducció- ☐ Parcialmn por unidad de tiempo)?

- ☐ Sí, con índices de reducción de exposición agregada.
- ☐ Sí, pero sólo en proyectos o campañas específicas.
- ☐ No, aunqu- ☐ Parcialm relevante.
- ☐ No, y no se considera una prioridad.

7.5. ¿Se evalúa el imp- ☐ Parcialmciones de remediación en términos de riesgo residual?

- ☐ Sí, con indicad- ☐ Parcialm antes/después.
- ☐ Sí, pero sólo cualitativamente.
- ☐ Rara vez o sólo tras inci- ☐ ParcialmNo, no se evalúa el riesgo residual.

8. Indicadores de resiliencia, continuidad y resultados

8.1. En el último año, ¿ha sufrido su organización incidentes de seguridad con impacto operativo releva-

- ☐ Parcialm, múltiples incidentes significativos.
- ☐ Sí, uno o- ☐ Parcialms significativos.
- ☐ Algún incidente menor, sin impacto relevante.
- ☐ No, ninguno digno de mención (que sepamos).

8.2. ¿Se mide el tiempo medio de recuperación de servicios críticos tras incidentes (MTTR de servicio)?

- ☐ Sí, con métricas consolidadas y revis- ☐ Parcialms.
- ☐ Sí, pero sólo en algunos servicios.
- ☐ Se mide de forma ad hoc.
- ☐ No, no se mide formalmente.

8.3. ¿Existe una relación visible entre la adopción de CTEM y la reducción de incidentes graves en su organización?

- ☐ Sí, claramente observab- ☐ Parcialmuencia y/o severidad).
- ☐ Sí, pero todavía con datos limitados.
- ☐ No está claro; no vemos una correlación evid- ☐ Parcialm se ha analizado.

8.4. ¿Integra CTEM indicadores de continuidad de negoc- ☐ Parcialmdisponibilidad) en su análisis de exposición?

- ☐ Parcialmorma sistemática en activos y servicios críticos.
- ☐ Parcialmente, en algunos proc- ☐ Parcialm, se tratan en silos separ- ☐ Parcialm aplica / No sabe.

8.5. ¿Se reportan al máximo órgano de gobierno (Consejo, Patronato, etc.) indicadores que vinculan exposición, incidentes y continuidad?

- ☐ Sí, en f- ☐ Parcialms de mando periódicos.
- ☐ Sí, pero de forma resumida o esporádica.
- ☐ Raramente; sólo tras incidentes relevantes.
- ☐ No, nunca.

9. Alineamiento con marcos normativos y regulato- ☐ Parcialmtá su organización sujeta a NIS2, DORA u otros marcos europeos de ciberseguridad?

- ☐ Sí, NIS2.
- ☐ Sí, DORA.
- ☐ Sí, ambos.
- ☐ Otros marcos sectoriales (especifique): _____
-

☐ No, no estamos directam- ☐ Parcialm

9.2. ¿Integra explícitamente las obligaciones de NIS2/DORA en su programa CTEM (por ejemplo, gestión de riesgos, incident reporting, continuidad, terceros)?

- ☐ Sí, CTEM es uno de los pilares para el cumplimiento.

- ☐ Parcialmente, en algunos do- ☐ ParcialmNo, se gestionan por vías separadas.
- ☐ No aplica / No sabe.

☐ No, no estamos directam- ☐ Parcialm

9.2. ¿Integra explícitamente las obligaciones de NIS2/DORA en su programa CTEM (por ejemplo, gestión de riesgos, incident reporting, continuidad, terceros)?

☐ Sí, CTEM es uno de los pilares para el cumplimiento.

9.3. ¿Utiliza marcos como NIST CSF, ISO 27001 o MITRE ATT&CK para estructurar las métricas e indicadores CTEM?

- ☐ Parcialm referencia principal.
- ☐ Sí, como referencia secunda- ☐ Parcialm pero lo estamos considerando.
- ☐ No, nos basamos en marcos propios.

9.4. ¿Se utilizan los resultados de CTEM para evidenciar cumplimiento ante audit- ☐ Parcialmores?

- ☐ Sí, de forma habitual.
- ☐ Sí, pero de forma limitada.
- ☐ Rara vez.
- ☐ No, todavía no.

9.5. ¿Qué porcentaje de las recomendaciones/iniciativas derivadas de CTEM se material- ☐ Parcialms organizativos o inversiones aprobadas?

- ☐ Más del 75 %.
- ☐ Parcialm 50 % y el 75 %.
- ☐ Entre el- ☐ Parcialm%.
- ☐ Menos del 25 %.
- ☐ Parcialmde / No sabe.

10. Tecnología CTEM, datos y herramie- ☐ Parcialm ☐ Parcialmanización de una o varias plataformas específicas de gestión de exposición (CTEM, ASM, - ☐ Parcialm.)?

- ☐ Sí, una plataforma integrada que cubre la mayor parte de necesid- ☐ Parcialm, varias herramientas especializadas (CTEM, ASM, BAS, etc.).
- ☐ Parcialmramientas de gestión de vulnerabilidades “clásic- ☐ Parcialmncipalmente hojas de cálculo, scripts y b- ☐ Parcialm
- ☐ Ninguna de las anteriores.

10.2. ¿Cómo se integran- ☐ Parcialmexposi- ☐ Parcialmilidades, configuraciones, identidades, terceros,- ☐ Parcialm En un lago de datos o repositorio central con modelado específico para riesgo.

- ☐ Parcialm integraciones parciales entre herramientas.
- ☐ Mediante procesos manuales (exportar/importar, hojas de cálculo).
- ☐ Parcialmtegran de forma relevante.

10.3. ¿Se automatiza la creación de ticke- ☐ Parcialm remediación a partir de hallazgos CTEM?

- ☐ Sí, de forma sistemática y bidireccional (estado de tickets realimenta CTEM).
- ☐ Parcialm con automatización limitada.
- ☐ A veces, pero predominan los procesos manuales.
- ☐ No, todo se gestiona manualm- ☐ ParcialmSe emplean analítica avanzada o IA para correlacionar exposiciones y priorizar?
- ☐ Sí, de forma relevante (modelos de rie- ☐ Parcialminámico, etc.).
- ☐ Sí, pero más como apoyo puntual.
- ☐ No, pero se está evaluando.
- ☐ No, no se utiliza en este ám- ☐ ParcialmDispone de cuadros de mando específicos CTEM para distintos perfiles (técnico, gestión, dirección)?
- ☐ Sí, con vistas diferenciadas por rol.
- ☐ Sí, pero bastante homogéneos - ☐ Parcialm ☐ No, sólo existen vistas técnicas.
- ☐ No, la información se presenta de forma ad hoc.
- ☐ No, todo se gestiona manualm- ☐ ParcialmSe emplean analítica avanzada o IA para correlacionar exposiciones y priorizar?
- ☐ Sí, de forma relevante (modelos de rie- ☐ Parcialminámico, etc.).
- ☐ No, no se utiliza en este ám- ☐ ParcialmDispone de cuadros de mando específicos CTEM para distintos perfiles (técnico, gestión, dirección)?
- ☐ Sí, con vistas diferenciadas por rol.

11. Métricas financieras, IGM y retorno de inversión (ROI)

11.1. ¿Asocia su programa CTEM a métricas financieras (pérdidas evitadas, coste de incidentes, impacto en continu- ☐ Parcialm- ☐ Sí, con modelos cuantitativos explícitos (por ejemplo, análisis de pérdidas esperadas).

- ☐ Sí, con e- ☐ Parcialmalitativas (niveles de impacto).

- ☐ Parcialmente, en algunos proye- ☐ Parcialm- ☐ No, no existe esa asociación.

11.2. ¿Calcula o estima el retorno de inversión (ROI) de las iniciativa- ☐ Parcialm Sí, a nivel de programa.

- ☐ Sí, a nivel de iniciativas concretas.

- ☐ Sólo en casos aislados.

- ☐ No, nunca.

11.3. ¿Dispone de un índice global de- ☐ Parcialm para CTEM u otro marco de exposición?

- ☐ Sí, formal y revisado periódicamente.
- ☐ Sí, pero- ☐ Parcialm a autoevaluación interna.
- ☐ No, pero se está desarrollando.
- ☐ No, no disponemos de IGM.

11.4. ¿Se usan métricas CTEM para prior- ☐ Parcialmto entre distintas líneas de defensa (prevención, detección, respuesta, resiliencia)?

- ☐ Sí, de forma explícita- ☐ Parcialmto sigue al riesgo).
- ☐ Sí, pero con peso limitado.
- ☐ No, el presupuesto se decide por otros criterios.
- ☐ No sabe / No responde.

11.5. ¿Hasta qué punto consi- ☐ Parcialmha contribuido a justificar inversiones en cibersegur- ☐ Parcialmlta dirección?

- ☐ De forma decisiva.
- ☐ De forma relevante.
- ☐ Marginalmente.
- ☐ Prácticam- ☐ Parcialm ☐ No aplica (no se utiliza CTEM para esto).

12. Visión de futuro y obstáculos

12.1. ¿Cuáles son los principales obstáculos - ☐ Parcialmn CTEM en su organización? (puede seleccionar hasta tres)

- ☐ Falta de recursos humanos especializados.
- ☐ Falta de presupuesto.
- ☐ Complejidad tecnológica / integración de herramientas.
- ☐ Parcialm apoyo de la alta dirección.
- ☐ Dificultad para obtener datos fiables.
- ☐ Cultura organizativa resist- ☐ Parcialm ☐ Parcialm (especifique brevemente): _____

12.2. En una escala del 1 al 5, ¿cómo valora la prior- ☐ Parcialmc- ☐ Parcialm su organización en los próximos 2-3 años?

- ☐ 1 – Irrelevante, tenemos otras preocupaciones.
- ☐ 2 – Importante, pero no prioritaria.
- ☐ 3 – Relevante, se le presta atención creciente.
- ☐ 4 – Prioritaria, con iniciativas claras en ma- ☐ Parcialm– Crítica, eje central de la estrategia de ciberseguridad.

12.3. ¿Estaría dispuesto su organización a participar en iniciativas sectoriales o nacionales de intercambio de información sobre exposición a amenazas?

- ☐ Parcialmvm- ☐ Parcialmdo métricas y datos agregados).
- ☐ Sí, pero con intercambio limitado.
- ☐ Quizá, según condicione- ☐ Parcialmialidad.
- ☐ No, preferimos no compartir ese tipo de información.

12.4. Si pud- ☐ Parcialmúnico cambio para facilitar CTEM en su organización, ¿cuál s- ☐ Parcialmta abierta:

_____ - ☐ Parcialm

Gracias por el tiempo, la paciencia y el coraje de mirarse en el es- ☐ Parcialmosición continua.